课程编号：

《开源创新思维》
平时作业报告

姓　　名	（待填）	学　　号	（待填）
班　　级	（待填）	指 导 教 师	祝欣蓉
开 设 学 期	2026-2027 秋 季 学 期		
开 设 时 间	第 1 周 — — 第 16 周		
报 告 日 期	2026 年 10 月 29 日		
评 定 成 绩		评　　定　　人	祝欣蓉
		评 定 日 期	

上海杉达学院

1、开源项目介绍

1.1 项目概况

本次作业选取 Apache 软件基金会 Commons 子项目的 Apache Commons Text（Maven 坐标 org.apache.commons:commons-text:1.12.0，2024 年 4 月发布）作为被审计的开源项目。该项目 2014 年自 Commons Lang 的文本处理模块拆分而来，提供字符串插值（StringSubstitutor）、文本相似度（Jaro-Winkler、Levenshtein 等）、字符串转义、最长公共子序列、文本差分等通用算法，是 Java 生态中使用广泛的底层类库。

对官方源码发布包的统计：共 242 个文件，其中 Java 源文件 201 个（main 107 个、test 94 个），约 5.2 万 行代码；其余为 pom.xml、文档、CI 配置及少量测试资源文件。

1.2 发布物的许可证构成

该项目的合规声明符合 ASF 标准发布要求：根目录 LICENSE.txt 为 Apache License 2.0 全文；NOTICE.txt 声明“Apache Commons Text，Copyright 2014-2024 The Apache Software Foundation”；pom.xml 中的 <license> 元数据与上述声明一致。运行时依赖仅 commons-lang3 3.14.0（同为 Apache-2.0）；另声明 junit、mockito 等 8 个 test 作用域依赖，不随发布物分发。

1.3 选取理由

一是治理规范：ASF 发布物必须附带 LICENSE 与 NOTICE 文件，且项目用 Apache Rat 做发布审计门禁，便于将工具结果与项目自身声明逐条对照；二是文件类型多样，可检验工具对非代码文件的判定能力；三是规模适中，242 个文件可全部人工复核，符合“自动扫描＋人工确认”的合规方法论。

2、许可证合规工具的选型与安装

2.1 选型过程与依据

按照《33 款开源软件许可合规工具选型手册》的“选型三步法”：本次要解决的问题是“对源码目录做许可证、版权与包依赖识别”，属于源码扫描引擎范畴；被审对象是 Java 源码加测试资源的普通源码树；扫描环境为 Windows 11 个人电脑（无 JDK/Maven，不宜部署服务端）。据此对候选工具逐条对比（表 1），最终选定 ScanCode Toolkit 32.5.0。

表 1　候选工具选型对比

工具	许可证	与本项目匹配的优点	选型结论
ScanCode Toolkit	Apache-2.0	许可证/版权/包/依赖识别准确；输出 JSON/HTML/CSV/SPDX；手册评为首选	选定：个人电脑即可运行
Apache Rat	Apache-2.0	Maven/Ant 插件查许可证头	不选：本机无 JDK/Maven；仅查许可证头

工具	许可证	与本项目匹配的优点	选型结论
Fossology / FOSSLight	GPL-2.0 / AGPL-3.0	Web 平台、多引擎	不选：需服务端数据库，部署过重
ORT / Licensee.js 等	Apache-2.0 / MIT	端到端流水线；npm 依赖检查	不选：ORT 需联网下载全部依赖；npm 类仅适用 npm 生态

2.2 安装过程

扫描环境为 Windows 11、Python 3.13.12。为避免污染全局环境，先以 python -m venv .venv-scancode 创建独立虚拟环境，再在其中安装 ScanCode Toolkit 32.5.0，并以 scancode --version 验证可用。ScanCode 为纯 Python 实现，无需数据库或外部服务，首次扫描时自动构建许可证规则索引。安装问题及解决见表 2。

2.3 安装过程中遇到的问题及解决

表 2 安装问题记录与解决方案

问题	现象	解决
国内镜像缺新版包	镜像索引只解析出旧版 sdist，pip 报 No matching distribution	改用阿里云镜像，定位 32.5.0 cp313 wheel 本地安装
大文件下载反复中断	126 MB wheel 下载多次超时/SSL 中断，pip 重试 17 分钟后失败	按 1 MB 分块、HTTP Range 六线程并发断点下载，zipfile 校验后安装
插件钩子报错	启动报 did not find any 'pre_scan' hooks	pluggy 1.7.0 与 plugincode 32.0.0 不兼容，降级 pluggy==1.5.0
环境隔离与中文乱码	全局安装污染系统 Python；控制台 GBK 显示异常	python -m venv 独立环境；--json-pp 输出 UTF-8 文件

3、工具输出的检测报告

3.1 扫描命令与参数

```
scancode -clpieu -n 4 --json-pp scancode-result.json --html scancode-report.html --csv scancode-summary.csv commons-text-rel-commons-text-1.12.0
```

参数含义：-l 许可证、-c 版权、-p 软件包、-i 文件信息、-e/-u 邮箱与 URL，-n 4 为并行进程数。全部文件扫描耗时约 93.32 秒，同时输出机器可读的 JSON 与人可读的 HTML、CSV 报告。

3.2 总体结果

表 3 扫描总体统计

统计指标	结果
扫描对象	commons-text-1.12.0 源码树（242 个文件、46 个目录，2.15 MB）
检出许可证的文件	237 个（占 98.0%）；未检出 5 个（占 2.0%）
检出许可证/规则种类	7 种（明细见表 4）
版权声明（去重）	1 条：Copyright 2014-2024 The Apache Software

统计指标	结果
	Foundation
检出软件包（purl）	1 个 ： pkg:maven/org.apache.commons/commons-text@1.12.0
扫描耗时	93.32 秒（4 进程并行，约 2.75 文件/秒，0 个错误）

3.3 许可证检出分布

按 SPDX 标识符汇总各许可证命中的文件数如表 4（同一文件命中多个规则时分别计数）。

表 4 许可证检出分布

许可证（SPDX 规则）	文件数	代表文件与说明
apache-2.0	236	全部 Java 源码、pom.xml、LICENSE.txt、.asf.yaml 等
generic-cla	2	README.md、CONTRIBUTING.md：命中“贡献者许可协议（CLA）”通用规则，属声明类文本
unknown-license-reference	1	README.md：提及许可证但未附全文，需人工确认
gpl-2.0 等组合表达式	1	lcs-perf-analysis-inputs.csv：测试输入语料，详见 4.2 节

3.4 未检出许可证的文件

共 5 个文件未检出许可证，人工归类为三类：一是项目自身在 pom.xml 的 apache-rat-plugin excludes 中显式豁免的文件（stringEscapeUtilsTestData.txt、download_text.cgi 等）；二是构建与 CI 元数据（.gitignore、.asf.yaml、.github/workflows/*.yml 等）；三是纯二进制资源（.xcf、.png）与代码覆盖率文件。上述文件均非需要许可声明的源代码。

4、检测报告详细分析

4.1 主许可证判定与声明一致性

242 个文件中有 236 个检出 apache-2.0（占 97.5%），覆盖全部 201 个 Java 源文件、17 个 XML 文件及全部项目声明文件。工具判定结果与项目自带的三处声明——LICENSE.txt（Apache-2.0 全文）、NOTICE.txt（ASF 版权归属）、pom.xml 的 <license> 元数据——完全一致，未发现“代码实际许可证与项目声明不符”的情形。

4.2 GPL-2.0 命中的性质判定

最值得关注的是：ScanCode 在 src/test/resources/.../lcs-perf-analysis-inputs.csv 中检出“gpl-1.0-plus AND gpl-2.0 AND classpath-exception-2.0 AND other-copyleft”表达式（命中第 1-2 行，得分 42.11）。人工复核确认：该文件是最长公共子序列性能基准的输入语料，前两行文本恰好复制自 OpenJDK 某源文件的 GPL-2.0 许可头片段，属于“内容里出现了许可文本”，而非“该文件以 GPL 授权”。判定：它不进入编译产物（test 资源不打包），不构成 copyleft 传染，但随源码包分发，建议替换语料或注明来源。这说明基于文本匹配的扫描器无法区分“许可文本巧合”与“真实授权”，印证了手册“误区 3”。

4.3 未检出文件与项目自身 RAT 排除清单的交叉验证

将未检出许可证的文件清单与 pom.xml 中 apache-rat-plugin 的 excludes 配置逐条比对：全部未检出文件要么落在该排除清单内（如 stringEscapeUtilsTestData.txt、download_text.cgi），要么属于 RAT 默认不要求许可头的二进制/统计文件（logo.xcf、logo.png、profile.jacoco）。这说明 ScanCode 的“无许可证”结果与 ASF 自身的发布审计口径一致，未发现应声明而未声明许可的文件。

4.4 版权信息集中化对扫描结果的影响

ScanCode 在全部文件中仅检出 1 条去重后的版权声明，即 NOTICE.txt 中的“Copyright 2014-2024 The Apache Software Foundation”；201 个 Java 文件头部均为 ASF 标准许可头，不含 Copyright 行，版权主体 100% 集中于 ASF。这符合 ASF 集中式版权惯例，但意味着仅依赖逐文件版权扫描生成 NOTICE/致谢文件会低估版权条数，必须与 NOTICE.txt 人工对账。

4.5 依赖层面的义务分析

运行时依赖 commons-lang3 3.14.0 为 Apache-2.0，随 jar 传递分发时义务仅为随附其 LICENSE 与 NOTICE、不将 Apache 商标用于宣传；8 个 test 作用域依赖不进入发布物，不触发任何许可证义务。这印证了手册“误区 1”：义务取决于“是否修改并对外分发”，而非“是否使用了某许可证的组件”；本项目依赖均为宽松许可证，无 copyleft 传染风险。

4.6 工具误报、漏报与局限性

一是文本巧合误报：lcs-perf-analysis-inputs.csv 得分仅 42.11 仍被报告，审计时应设置阈值并人工复核；二是通用规则的不确定性：generic-cla、unknown-license-reference 均需人工定性；三是统计偏差：对 ASF 集中式版权结构，逐文件版权检出偏少（见 4.4 节）；四是能力边界：工具不判断许可证兼容性、不输出合规义务清单。综上，扫描结果必须人工复核后才能形成合规结论。

表 5　合规风险清单与整改建议

风险/发现	等级	依据	整改建议
测试数据文件含 GPL-2.0 文本片段	低	lcs-perf-analysis-inputs.csv 第 1-2 行命中 GPL 规则（得分 42.11）	替换语料或注明来源；SBOM 中标注，避免下游审计误判
源码文件无文件级版权行	提示	Java 文件头部为 ASF 标准许可头，版权集中于 NOTICE.txt	随发布物附送 LICENSE 与 NOTICE 即满足 Apache-2.0 第 4 条
5 个文件未检出许可证	提示	均为 RAT 排除清单内或二进制/统计文件	维持现状；SBOM 中标记 n/a 并注明豁免依据

4.7 结论

本次扫描表明，Apache Commons Text 1.12.0 许可证合规状态良好：主许可证 Apache-2.0 与项目自带声明完全一致；唯一 GPL-2.0 命中经人工复核确认为测试语料文本巧合，不构成传染。ScanCode 识别准确、报告丰富，适合作为课程级合规审计的主力工具。

评价表格：

考核标准	得分
（1）报告格式规范、语言通顺（10%）；	
（2）质量标准分析合理（10%）；	
（3）测试方法分析全面、合理（20%）；	
（4）测试风险分析全面、合理（20%）；	
（5）测试总体测试策略全面、合理（30%）	
（6）测试充分性判断标准合理（10%）	